



CURSO OPENCLAW



CVE 2026.2.12 — Leitura Obrigatória

Módulo 2

Segurança

&

Hardening

Blindar

seu

servidor

OpenClaw

contra os

ataques

mais

DURAÇÃO

comuns

30-45 minutos

— 9

camadas

de

proteção,

01 Por Que Isso É Urgente

Em fevereiro de 2026, uma CVE com CVSS 8.8 comprometeu 30.000+ instâncias. Sem proteção, seu servidor está sob ataque agora.

● CVE 2026.2.12 — O que aconteceu

Uma vulnerabilidade crítica foi descoberta em instâncias OpenClaw expostas na internet. Mais de **30.000 instâncias** foram identificadas como vulneráveis antes do patch v2026.2.12. Servidores comprometidos tiveram **dados exfiltrados, API keys roubadas** e agentes usados para spam.

Além disso: servidores OpenClaw expostos recebem **1.000+ tentativas de brute force por dia**. Sem proteção, qualquer pessoa pode acessar seu agente e seus dados.

30k+

INSTÂNCIAS
COMPROMETIDAS

8.8

CVSS SCORE (CRÍTICO)

9

CAMADAS DE PROTEÇÃO

02 As 9 Camadas

Execute na ordem — cada camada protege contra um vetor de ataque diferente.

-  **Telegram Allowlist (dmPolicy)** URGENTE
CRÍTICO — fazer PRIMEIRO. Bloqueia comandos de usuários não autorizados via Telegram
-  **Firewall UFW** ALTO
Bloqueia todo tráfego de entrada não autorizado nas portas do servidor
-  **Fail2ban** ALTO
Bane automaticamente IPs que tentam brute force no SSH
-  **Cloudflare Tunnel** NOVO v2026
Acesso remoto seguro ao painel sem expor portas (obrigatório na v2026.3.2)
-  **Portas em 127.0.0.1** MÉDIO
Apps web só aceitam conexões locais — nunca 0.0.0.0
-  **SSH Hardening** MÉDIO
SSH key-only, sem login por senha, sem root remoto
-  **openclaw secrets audit** CRÍTICO
Detecta e remove API keys hardcodadas nos arquivos
-  **openclaw secrets apply** MÉDIO
Migra credenciais para cofre criptografado do OpenClaw
-  **Systemd + Secrets Sync** ROTINA
Garantir que rotação de credenciais é aplicada ao daemon

03 Camadas 1–3: Base

1 Telegram Allowlist — PRIMEIRO!

CRÍTICO — FAZER ANTES DO UFW

Configure o `dmPolicy` para **allowlist** antes de qualquer outra coisa. O UFW protege portas do servidor, mas o Telegram é conexão de SAÍDA — sem allowlist, qualquer pessoa que descobrir seu bot pode comandar seu agente.

```
# Verificar config atual
cat /root/.openclaw/openclaw.json | grep -A5 dmPolicy
```

bash



Se estiver "open", mude IMEDIATAMENTE para "allowlist"

Adicione APENAS os IDs dos usuários autorizados. Sem isso, o UFW não ajuda — o Telegram chega por conexão de saída, não por porta aberta.

2 Firewall UFW

~5 min

```
sudo apt install -y ufw
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow ssh
sudo ufw --force enable
sudo ufw status
```

bash

3 Fail2ban — Proteção SSH

~10 min

```
sudo apt install -y fail2ban

# Criar configuração customizada
```

bash

```
sudo cat > /etc/fail2ban/jail.local << 'EOF'
[sshd]
enabled = true
port = ssh
filter = sshd
logpath = /var/log/auth.log
maxretry = 5
bantime = 3600
findtime = 600
EOF
```

```
sudo systemctl enable fail2ban
sudo systemctl restart fail2ban
```

```
# Verificar status
sudo fail2ban-client status sshd
```



O que o Fail2ban faz

`maxretry = 5` — após 5 tentativas erradas em 10 min, bane o IP por 1 hora. Elimina 99% dos ataques de brute force automatizados.

04 Camadas 4–6: Acesso Remoto

4

☁ Cloudflare Tunnel

OBRIGATÓRIO na v2026.3.2

O WebSocket do painel OpenClaw agora só aceita conexões de **127.0.0.1** (loopback). Para acessar remotamente, **você precisa do Cloudflare Tunnel**. Não tem atalho.

bash

```
# Instalar cloudflared
curl -L https://github.com/cloudflare/cloudflared/releases/latest/download/cloudflared-
  -o cloudflared.deb
sudo dpkg -i cloudflared.deb

# Autenticar e criar tunnel
cloudflared tunnel login
cloudflared tunnel create meu-tunnel

# Configurar (porta 18789 = painel OpenClaw)
cat > ~/.cloudflared/config.yml << 'EOF'
tunnel: meu-tunnel
credentials-file: /root/.cloudflared/<TUNNEL_ID>.json

ingress:
  - hostname: painel.meudominio.com
    service: http://127.0.0.1:18789
  - service: http_status:404
EOF

cloudflared service install
systemctl enable cloudflared
systemctl start cloudflared
```



Por que Cloudflare Tunnel é melhor que abrir porta

Zero portas expostas na internet. Conexão de SAÍDA — servidor fica “invisível”. SSL/TLS automático. Proteção DDoS gratuita inclusa.

NUNCA use 0.0.0.0 — sempre 127.0.0.1 + tunnel.

5



Portas em 127.0.0.1

Toda aplicação web deve escutar apenas em localhost. Se tiver apps rodando:

- Mude binding de `0.0.0.0` para `127.0.0.1`
- Use Cloudflare Tunnel para acesso externo
- Nunca exponha portas direto na internet

6



SSH Hardening

bash

```
# Verificar se root login com senha está ativo
grep "PermitRootLogin" /etc/ssh/sshd_config

# Ideal: chave SSH apenas (sem senha)
# PermitRootLogin prohibit-password
```



Configure chaves SSH antes de desabilitar senha

Certifique-se de que sua chave SSH funciona antes de desabilitar login por senha — caso contrário você pode se trancar para fora do servidor.

05 Camadas 7–9: Credenciais



A CVE 2026.2.12 explorou exatamente isso

API keys hardcodadas em arquivos de configuração. Se alguém acessa seu servidor, pega TODAS as chaves de uma vez. O comando `openclaw secrets` resolve isso.

7



Auditar Credenciais Expostas

Escaneia todos os arquivos do workspace procurando API keys hardcodadas:

```
bash

# Detectar chaves expostas
openclaw secrets audit

# Se encontrar algo, vai listar caminho e linha exata
# Exemplo de output preocupante:
⚠ Found: ANTHROPIC_API_KEY in /root/.openclaw/openclaw.json:45
⚠ Found: OPENAI_API_KEY in /root/.openclaw/workspace/config.js:12
```

8



Migrar para Cofre Seguro

```
bash

# Migrar credenciais para cofre criptografado
openclaw secrets apply

# Verificar que tudo foi migrado (deve retornar limpo)
openclaw secrets audit
✅ No exposed credentials found

# Rotação trimestral — atualizar uma chave
openclaw secrets set ANTHROPIC_API_KEY=sk-ant-nova-chave-aqui
```



Compatibilidade com .env manual

Se você tem um `.env` com chaves, o `openclaw secrets apply` lê de lá também e migra pro sistema seguro. Após migração, o `.env` manual pode ser removido.



Systemd + Secrets Sync

Quando trocar qualquer credencial, o systemd precisa saber — caso contrário continua usando o valor antigo:

bash

```
# 1. Atualizar o secret
openclaw secrets set NOME_DA_CHAVE=novo-valor

# 2. Atualizar override do systemd (se necessário)
sudo systemctl edit openclaw

# 3. Recarregar e reiniciar
sudo systemctl daemon-reload
sudo systemctl restart openclaw
```



Armadilha comum — horas de debug perdidas

O systemd override tem prioridade sobre o sistema de secrets. Se trocar só o secret mas o override tiver o valor antigo, vai continuar usando o antigo. Sempre sincronize os dois.

06 Checklist Final

Execute cada item na ordem. Um servidor blindado contra os ataques mais comuns.

✓ 9 Camadas de Proteção

- ☐ **dmPolicy = allowlist** — PRIMEIRO, antes do UFW
- ☐ **UFW ativo** — deny incoming, allow ssh
- ☐ **Fail2ban ativo** — maxretry=5, bantime=3600
- ☐ **Cloudflare Tunnel configurado** — painel via 127.0.0.1:18789
- ☐ **Portas em 127.0.0.1** — nunca 0.0.0.0
- ☐ **SSH hardened** — key-only, PermitRootLogin prohibit-password
- ☐ **openclaw secrets audit** — zero resultados
- ☐ **openclaw secrets apply** — credenciais no cofre seguro
- ☐ **Rotação trimestral agendada** — lembrete recorrente criado
- ☐ **Systemd + secrets sincronizados** — testado após rotação

🎯 Resultado Esperado

Servidor blindado contra todos os vetores de ataque conhecidos, incluindo o da CVE 2026.2.12. Reporte o status de cada item ao seu agente OpenClaw para confirmação.

🔄 Rotação Trimestral

A cada 3 meses, gere novas chaves nos painéis (Anthropic, OpenAI, Telegram) e atualize com `openclaw secrets set`. Chaves antigas que vazam ficam inúteis após a rotação.



PRÓXIMA AULA

N-1 — Configurar Credenciais: API Key Anthropic + OpenAI